



UNIVERSIDAD PRIVADA DE TACNA

FACULTAD DE INGENIERÍA

Escuela Profesional de Ingeniería de Sistemas

**Proyecto: Sistema Verificador de Cumplimiento
OWASP**

Curso: Calidad y Pruebas de Software

Docente: Patrick Jose Cuadros Quiroga

Integrantes:

- Andia Navarro, Diego Fabrizio (2022073906)
- Concha Llaca, Gerardo Alejandro (2017057849)

Tacna – Perú

2026

CONTROL DE VERSIONES

Versión	Hecha por	Revisada por	Aprobada por	Fecha	Motivo
1.0	Equipo	Profesor	-	24/06/2026	Versión inicial del diccionario de datos
1.1	Equipo	Profesor	-	02/07/2026	Ampliación del diccionario para incluir todas las tablas del sistema (scans, users, api_tokens, access_logs, admin_sessions, system_settings)

ÍNDICE

1. Introducción	3
2. Diagrama de la Base de Datos (Estructura de Almacenamiento)	3
3. Diccionario de Datos	4
3.1 Tabla: users	4
3.2 Tabla: scans	5
3.3 Tabla: api_tokens	6
3.4 Tabla: access_logs	7
3.5 Tabla: admin_sessions	8
3.6 Tabla: system_settings	9
4. Índices e Índices Compuestos	9
5. Estructura Serializada del Campo findings_json	10

1. Introducción

Este documento detalla el diseño de almacenamiento de datos del Sistema Verificador de Cumplimiento OWASP. El sistema utiliza una base de datos centralizada configurada y administrada mediante el archivo [store.py](#). Soporta dos motores de base de datos de manera intercambiable mediante variables de entorno (DB_TYPE): MySQL/MariaDB para producción y SQLite3 local para desarrollo y pruebas rápidas (almacenada en data/scans.sqlite3).

2. Diagrama de la Base de Datos (Estructura de Almacenamiento)

A continuación se presenta el modelo relacional del sistema que incluye el control de accesos, auditorías, gestión de usuarios, sesiones administrativas y el registro detallado de los análisis de seguridad realizados.

```
USERS {
  VARCHAR_255 username PK "Nombre de usuario único"
  VARCHAR_255 password_hash "Hash SHA-256 de la contraseña"
  VARCHAR_50 role "Rol de usuario (user, admin)"
  DATETIME created_at "Fecha de registro"
  VARCHAR_255 email "Correo electrónico"
  VARCHAR_255 github_token "Token OAuth opcional para GitHub"
}
SCANS {
  INTEGER id PK "Identificador único (Autoincrement)"
  VARCHAR_50 target_type "Tipo de escaneo (code, url, archivo, github_repo)"
  LONGTEXT target_value "Código, URL o ruta escaneada"
  VARCHAR_50 status "Estado (completed, failed, error)"
  INTEGER score "Calificación de seguridad (0 a 100)"
  DATETIME created_at "Fecha y hora del escaneo"
  LONGTEXT findings_json "Arreglo serializado de hallazgos en JSON"
  VARCHAR_255 username FK "Usuario que solicitó el análisis (puede ser NULL)"
}
API_TOKENS {
  VARCHAR_255 token PK "Clave de API única para integraciones"
  VARCHAR_255 user "Usuario asociado al token"
  DATETIME created_at "Fecha de generación"
  DATETIME last_used "Fecha de última validación"
  TINYINT_1 is_active "Estado del token (1=Activo, 0=Inactivo)"
}
ACCESS_LOGS {
  INTEGER id PK "Identificador único (Autoincrement)"
  VARCHAR_255 path "Ruta del endpoint accedido"
  VARCHAR_50 ip "Dirección IP del cliente"
```

```
TEXT user_agent "Agente de usuario del navegador/cliente"
VARCHAR_255 username FK "Usuario autenticado (puede ser NULL)"
DATETIME created_at "Fecha y hora del acceso"
}
ADMIN_SESSIONS {
  VARCHAR_255 session_id PK "Identificador único de sesión web"
  VARCHAR_255 username "Nombre del administrador"
  DATETIME created_at "Fecha de inicio de sesión"
  DOUBLE expires_at "Tiempo epoch de expiración de sesión"
}
SYSTEM_SETTINGS {
  VARCHAR_255 setting_key PK "Clave de configuración global"
  VARCHAR_255 setting_value "Valor asignado a la clave"
}

USERS ||--o{ SCANS : "solicita"
USERS ||--o{ API_TOKENS : "posee"
USERS ||--o{ ACCESS_LOGS : "genera"
USERS ||--o{ ADMIN_SESSIONS : "inicia"
\
```

3. Diccionario de Datos

3.1 Tabla: users

Registra las cuentas de usuario y los roles autorizados en la plataforma web y la API.

Nombre del Campo	Tipo de Dato (MySQL)	Tipo de Dato (SQLite)	Llave	Restricciones	Descripción / Notas
username	VARCHAR(255)	TEXT	PK	PRIMARY KEY, NOT NULL	Nombre de usuario único para la autenticación en el sistema.
password_hash	VARCHAR(255)	TEXT	-	NOT NULL	Contraseña cifrada en formato hash SHA-256.

role	VARCHAR(50)	TEXT	-	NOT NULL, DEFAULT 'user'	Rol del usuario para control de accesos. Valores comunes: 'user', 'admin'.
created_at	DATETIME	TEXT	-	NOT NULL	Fecha y hora de creación de la cuenta de usuario.
email	VARCHAR(255)	TEXT	-	NULL	Dirección de correo electrónico del usuario.
github_token	VARCHAR(255)	TEXT	-	NULL	Token de acceso de GitHub para autenticar análisis de repositorios privados.

3.2 Tabla: scans

Registra el historial de análisis de seguridad de código, repositorios o URLs, con las puntuaciones y hallazgos detallados.

Nombre del Campo	Tipo de Dato (MySQL)	Tipo de Dato (SQLite)	Llave	Restricciones	Descripción / Notas
id	INT	INTEGER	PK	PRIMARY KEY, AUTOINCREMENT	Identificador numérico correlativo y autoincremental de cada escaneo.
target_type	VARCHAR(50)	TEXT	-	NOT NULL	Tipo de escaneo realizado. Valores: 'code', 'url', 'archivo', 'github_repo'.

target_value	LONGTEXT	TEXT	-	NOT NULL	El recurso que fue escaneado (URL, ruta del archivo o código fuente copiado).
status	VARCHAR(50)	TEXT	-	NOT NULL	Estado del análisis. Valores comunes: 'completed', 'failed', 'error'.
score	INT	INTEGER	-	NOT NULL	Calificación final de seguridad (0 a 100) calculada tras descontar penalizaciones.
created_at	DATETIME	TEXT	-	NOT NULL	Marca de tiempo ISO 8601 que registra cuándo se ejecutó el análisis.
findings_json	LONGTEXT	TEXT	-	NOT NULL	Cadena JSON estructurada que contiene el arreglo detallado con los hallazgos de OWASP.
username	VARCHAR(255)	TEXT	FK	NULL, FOREIGN KEY	Nombre del usuario que solicitó el escaneo. Referencia a users(username).

3.3 Tabla: api_tokens

Almacena los tokens que permiten a los desarrolladores y sistemas externos (CI/CD, CLI) autenticarse y usar el escáner.

Nombre del Campo	Tipo de Dato (MySQL)	Tipo de Dato (SQLite)	Llave	Restricciones	Descripción / Notas
token	VARCHAR(255)	TEXT	PK	PRIMARY KEY, NOT NULL	Token único en formato UUID4 para solicitudes a la API REST.
user	VARCHAR(255)	TEXT	FK	NOT NULL, FOREIGN KEY	Nombre de usuario que posee y utiliza el token. Referencia a users(username).
created_at	DATETIME	TEXT	-	NOT NULL	Fecha y hora en la que el token fue generado.
last_used	DATETIME	TEXT	-	NOT NULL	Registro de la última fecha y hora de llamada de API usando este token.
is_active	TINYINT(1)	INTEGER	-	NOT NULL, DEFAULT 1	Define si el token está activo (1) o deshabilitado (0).

3.4 Tabla: access_logs

Almacena la bitácora de accesos y auditoría de peticiones para fines de seguridad y monitoreo.

Nombre del Campo	Tipo de Dato (MySQL)	Tipo de Dato (SQLite)	Llave	Restricciones	Descripción / Notas
id	INT	INTEGER	PK	PRIMARY KEY, AUTOINCREMENT	Identificador único del registro de auditoría.
path	VARCHAR(255)	TEXT	-	NOT NULL	Ruta o URL de la API/Web solicitada (ej. "/api/v1/scan").

ip	VARCHAR(50)	TEXT	-	NOT NULL	Dirección IP del cliente que originó la petición.
user_agent	TEXT	TEXT	-	NOT NULL	Agente de usuario del navegador o cliente HTTP utilizado.
username	VARCHAR(255)	TEXT	FK	NULL, FOREIGN KEY	Nombre del usuario autenticado al realizar la petición, si procede.
created_at	DATETIME	TEXT	-	NOT NULL	Registro de fecha y hora exacta de la petición.

3.5 Tabla: **admin_sessions**

Mantiene el registro de sesiones activas en el panel de administración web.

Nombre del Campo	Tipo de Dato (MySQL)	Tipo de Dato (SQLite)	Llave	Restricciones	Descripción / Notas
session_id	VARCHAR(255)	TEXT	PK	PRIMARY KEY, NOT NULL	Token UUID único del lado del cliente almacenado en cookies de sesión.
username	VARCHAR(255)	TEXT	FK	NOT NULL, FOREIGN KEY	Nombre del administrador de la sesión. Referencia a users(username).
created_at	DATETIME	TEXT	-	NOT NULL	Fecha y hora de inicio de sesión del administrador.
expires_at	DOUBLE	REAL	-	NOT NULL	Tiempo de expiración de la

					sesión en formato Timestamp Epoch (segundos).
--	--	--	--	--	---

3.6 Tabla: system_settings

Almacena parámetros de configuración globales y dinámicos para el comportamiento del sistema.

Nombre del Campo	Tipo de Dato (MySQL)	Tipo de Dato (SQLite)	Llave	Restricciones	Descripción / Notas
setting_key	VARCHAR(255)	TEXT	PK	PRIMARY KEY, NOT NULL	Nombre de clave identificadora de la configuración global.
setting_value	VARCHAR(255)	TEXT	-	NOT NULL	Valor configurado asociado a la clave.

4. Índices e Índices Compuestos

Para optimizar las búsquedas frecuentes del panel administrativo y dashboard de escaneos:

Nombre del Índice	Tabla	Campo Indexado	Tipo / Orden	Propósito
idx_scans_created_at	scans	created_at	DESC	Acelera la carga de los escaneos recientes en el dashboard.

5. Estructura Serializada del Campo findings_json

Los hallazgos de seguridad se estructuran dentro de findings_json en la tabla scans como un arreglo JSON de objetos para optimizar el almacenamiento relacional de registros dinámicos.

Atributo JSON	Tipo de Dato	Descripción / Ejemplos
rule_id	String	Identificador del patrón OWASP evaluado (ej. "OWASP-A02", "OWASP-A06-CVE").
title	String	Título del riesgo detectado (ej. "Fallas Criptográficas - Exposición de Secretos").
severity	String	Nivel de gravedad del hallazgo ("high", "medium", "low").
description	String	Detalle de la regla vulnerada y el peligro potencial.
evidence	String	Fragmento del código o cabecera HTTP que detonó la alerta.
penalty	Integer	Penalización numérica restada del score (ej: 30 para high, 15 para medium, 5 para low).
remediation	String	Pasos de solución detallados y mejores prácticas recomendadas para solucionar el fallo.

Ejemplo de un hallazgo en findings_json:

```
`json
[
{
"rule_id": "OWASP-A02",
"title": "Fallas Criptográficas - Exposición de Secretos",
"severity": "high",
"description": "Secretos, contraseñas o claves hardcodeadas detectadas en el código.",
"evidence": "Coincidencia encontrada: password = \"secreto\"",
"penalty": 30,
"remediation": "1. Nunca hardcodear secretos\n2. Usar variables de entorno (os.getenv())\n3. Implementar secret manager (Azure Key Vault, HashiCorp Vault)\n4. Rotar credenciales regularmente"
}
]
```